Implementation guide: application level

Oct 30, 2026

How an engineering team takes one product, or one product family, from scope decision to EU declaration of conformity under Regulation (EU) 2024/2847, and keeps it compliant through the support period. Each section names the artefact it produces and the checklist line it satisfies.

1. Purpose and how to run this guide

This guide takes one product or product family from scope decision to EU declaration of conformity, and keeps it compliant through the support period. It is written for product security engineers, tech leads, release and platform engineers and the PSIRT. The knowledge base sections hold the legal detail; this guide holds procedures, patterns, templates and acceptance criteria.

Run it per product or family, in section order. Each section produces one named artefact, and the next section consumes it. Skipping ahead produces evidence nobody can trace to a decision, the failure early adopters report most often (see Engineering compliance programme).

Section	Artefact produced	Requirement checklist served
2 Define the product	Product definition record	1 scope gate; 10 transition
3 Risk assessment	Art 13 risk assessment with applicability matrix	2 Annex I Part I; 4 Article 13
4 Annex I patterns	Control notes and acceptance evidence	2 Annex I Part I
5 SDLC integration	Release gate records and attestations	2; 3 Part II; 4
6 SBOM pipeline	Signed SBOM per release	3 Part II
7 Secure updates	Update design note and tests	2; 3
8 Vulnerability handling	CVD policy, security.txt, case files, advisories	3 Part II; 4
9 Open source	Due-diligence records; FOSS determination memo	3; 4; 9 other operators
10 Reporting runbook	Product reporting data pack	5 reporting

Section	Artefact produced	Requirement checklist served
11 Documentation set	Annex VII file, Annex II document, declaration	6 Annex II; 7 documentation and declaration
12 Conformity preparation	Evidence index; Module A record or body pack	8 modules
13 Worked example	Reference walk-through	All
14 Pitfalls	Review list	All

Three dates frame the work. Art 14 reporting has applied since 11 Sep 2026 to every in-scope product, including products already sold (Art 69(3)). Everything else applies from 11 Dec 2027; earlier products are caught only on substantial modification (Art 69(2)).

No harmonised standard is cited in the OJ and no notified body is designated. This guide therefore relies on Commission FAQ v1.4, guidance C(2026) 5252, ENISA advisories, BSI TR-03183 and draft standards, all non-binding. Drafts and vendor material are labelled as such, and each artefact should record which guidance it followed.

Each section opens with the point it makes, names the knowledge base section that holds the law, then gives the procedure. Tables list items against attributes, numbered lists give sequences, and `- [ ]` lines are acceptance criteria to tick with evidence. Code blocks show a CI step, a file or a document skeleton that can be copied and adapted.

The artefacts map one-to-one onto the Requirement checklists tab. Finish a section, tick its lines there with the artefact reference, and move on. Section 13 walks a fictional smart thermostat through sections 2 to 12; read it first if the shape of the end result is unclear.

2. Define the product

Every later artefact depends on an agreed product boundary, so fix it first and write it down. The boundary decides what the risk assessment covers and what the SBOM lists. It also decides which backend the declaration speaks for and whether one file can serve several variants.

Early adopters report inventories growing five-fold once versions, apps and cloud pieces are counted (OmniTrust, consultancy).

The legal tests are in Scope: what the CRA covers and Product classification. This section turns them into a procedure and a record.

Step 1: list the elements

Start from what the user receives and what it talks to. Include hardware, firmware, embedded operating system, host software, drivers, companion mobile and desktop apps, browser front-ends, cloud services and third-party services. For each element record who develops it, who operates it and which product functions depend on it.

Software needed to use the hardware is part of the product even when downloaded later from an app store. Guidance C(2026) 5252 para 25 and Examples 8 and 9 make a printer and its drivers, or a wearable and its app, one product. Software the product merely redirects to, such as an informational website, is not (para 194).

Step 2: apply the remote-data-processing test

A backend element is remote data processing (RDPS), and therefore part of the product, when three elements hold together (paras 184-188). Elements (ii) and (iii) are "decisive and cumulative".

1. The processing happens at a distance, which includes edge, on-premises and private-cloud deployments as much as public cloud.
2. Without it the product cannot perform one of its functions. "Functions" is wider than core functionality: sending commands, synchronising files, onboarding, configuration, identity and access management, and automated update distribution all count (paras 189-192). A function offered both remotely and manually still counts.
3. The software was designed and developed by the manufacturer or built solely for it to its specifications (paras 195-196). Licensing an existing third-party service, even slightly modified, fails this element; who operates it is "not a decisive factor".

The guidance examples anchor the boundary. For a mobile banking app, the bank's own API is RDPS; the ledger systems the app never talks to are not (section 8.3, para 205). An authentication portal issuing the tokens the product needs is RDPS; an informational website is not (para 194).

A smart thermostat's manufacturer-built cloud functions on third-party IaaS are RDPS (section 8.3).

Third-party SaaS integrated into the product, such as a support-chat widget or a generic storage service, is not RDPS. Treat it as a component under Art 13(5) due diligence with product-level mitigations (paras 197-202).

Telemetry analysed purely for statistics or future development is not RDPS (para 192). The data still counts for Annex I Part I item 2(g).

Write the result as a remote-function map: function, dependent service, developer, operator, local fallback behaviour, RDPS yes or no. Draft ETSI EN 304 621 MAS_TECH-2 (draft) adds that the product must not connect to undocumented remote services, so the map must be complete.

Step 3: decide variants and families

Variants sharing architecture, security-relevant design, intended purpose and risks may share one risk assessment, one technical file and one declaration (guidance paras 174-177). The declaration must list the variants. Differences in interfaces, software stacks, update mechanisms or remote connectivity must be reflected, and usually split the family.

Modules sold or licensed separately are separate products (para 145).

Record a family only when an engineer can name the shared security architecture document. A shared brand is not a family.

Step 4: write the intended-purpose statement

Intended purpose drives the risk assessment (Art 13(3)), the Annex II document (point 4) and classification. Write one paragraph covering what the product does, for whom, in what environment, with what connectivity and for how long. Add a foreseeable-use list, including misuse the design should tolerate, and the security environment the user is assumed to provide.

Where the product is tailor-made for one business user, record the contract clause that varies secure-by-default or free updates. The Commission FAQ v1.4 section 4.2 limits the carve-out to those two items. Minor customisation of a multi-tenant product does not qualify.

Step 5: name the core functionality and classify

State the single core functionality, then compare it against the technical descriptions in Implementing Regulation (EU) 2025/2392. Follow the eight-step self-classification procedure in Product classification; ignore embedded important components and ancillary functions, and classify from documentation and behaviour rather than marketing. Record "default", Class I, Class II or critical with the rationale and evidence consulted.

Step 6: select the route

Default products use Module A. Class I products cannot use Module A until a harmonised standard is cited, so plan for Module B+C or H and pre-contract candidate bodies. Class II and critical products need a notified body now.

A FOSS product in Annex III may use Module A if the technical file is published (Art 32(5)). The route table is in Conformity assessment and documentation; the preparation steps are in section 12.

Step 7: apply the per-version placing rule

For standalone software, every copy of a version is deemed placed on the market at its first offering (guidance paras 11-16, Example 1). Each substantially modified version is a new placing with its own declaration and declared support period. Non-substantial updates do not reset the date (Example 2), so the release process must record which releases cross the security-delta threshold (section 5).

For hardware with software, placing happens unit by unit when the hardware ships (para 25). Companion software released later is placed when the units are. Record both rules in the definition record so release engineering applies the right one.

Output: the product definition record

Field	Content	Source
Product name and identifiers	Commercial name, model, SKU list, type or serial scheme (Art 13(15))	Product management
Elements in the boundary	Hardware, firmware, host software, apps, RDPS modules and interfaces	Step 1
Remote-function map	Function, service, developer, operator, fallback, RDPS decision	Step 2
Third-party services as components	Service, provider, function served, due-diligence owner	Step 2
Family and variants	Variant list, shared architecture document, differences recorded	Step 3
Intended purpose and foreseeable use	One paragraph plus misuse list and assumed security environment	Step 4

Field	Content	Source
Expected time in use and support period	Years, rationale, end month and year per variant and version (Art 13(8), (19))	Product management
Core functionality and class	Statement, Implementing Regulation category or "default", rationale	Step 5
Conformity route	Module A, B+C, H or certificate; candidate bodies if needed	Step 6
Placing rule	Per-version software or per-unit hardware; substantial-modification trigger owner	Step 7
Economic-operator roles	Manufacturer, importer, distributor, authorised representative per market	Who the CRA regulates
Legacy status	Placed before 11 Dec 2027 yes or no; Art 69(2)-(3) consequences	Transition
Tailor-made terms	Contract reference for any 2(b) or Part II(8) variation, else "none"	Step 4
Review triggers	New variant, new backend, new sales model, substantial modification	Classification procedure step 8
Approvals	Product owner, product security, legal; date; version of this record	Governance

Keep the record under version control beside the technical file. It is the first entry in the Requirement checklists tab, checklist 1 scope gate, and it feeds checklist 10 transition.

3. Threat modelling and the Article 13 risk assessment

The Art 13 risk assessment decides which Annex I Part I items apply, so build it as a living engineering artefact. It rests on intended purpose, foreseeable use, conditions of use and expected time in use (Art 13(2)-(3)). It states per item whether and how 2(a) to 2(m) apply, justifies every "not applicable" and is updated through the support period (Art 13(3)-(4)).

The legal reading is in Annex I Part I: essential requirements for product properties; this section gives the method.

No methodology is mandated (Commission FAQ v1.4 section 4.1). Whatever method you choose, a market surveillance authority must be able to follow the trail from asset to threat to decision to evidence.

Method options

Method	Fits	What it gives the file	Reference
STRIDE on data-flow diagrams	Software products, apps, backends	Per-flow threats across six classes; trust boundaries; a diagram the ENISA Playbook calls for	ENISA Playbook v1.0 section 2.3 (illustrative method; Shostack four questions; "minimum viable model" for SMEs)
IEC 62443-3-2 zones and conduits	OT and industrial devices, gateways	Zone partitioning, conduit risk, security-level targets reusable in 62443-4-2 control selection	JRC-ENISA mapping places it against Part I point (1); IACS-scoped, not expected to be cited
BSI TR-03183-1 v1.0.0 method	Any product; teams without a mature process	ISO 31000-style flow: RH_RA.1 assets and threat modelling, RH_RA.1.2 impact 1-5 by likelihood, RH_RT.1 treatment, RH_DOC.1, RH_UPD.1; PASS, FAIL or N/A verdicts per control; section 4.8 report skeleton	BSI TR-03183-1 (non-binding, living document)
EN 18031 decision trees	Radio equipment already assessed under RED	Decision record per requirement: asset, interface, path, rationale, evidence; same control families reused in draft EN 40000-1-4	EN 18031-1:2024 (cited under RED only)

Combine them freely. A common pattern is BSI TR-03183-1 for structure and verdicts, with STRIDE on the data-flow diagram for threat discovery. Add 62443-3-2 zoning where the product sits in an industrial network, and record the method and the reason in the assessment header.

Inputs

1. The product definition record from section 2: boundary, remote-function map, variants, intended purpose, foreseeable use and misuse, expected time in use (Art 13(3)).
2. Conditions of use: operational environment, user capability, who administers it, network exposure, physical access.
3. Asset list in the three BSI classes. Data assets: credentials, keys, personal data. Functional assets: control functions, the update path. Security assets: root of trust, signing keys, audit log.
4. Architecture and data-flow diagrams showing every interface, including the product-to-RDPS boundary and each third-party service.
5. Component inventory with due-diligence status (section 9), because recital 58 asks for supplier dependencies to appear in the assessment.
6. Threat intelligence relevant to the product class, including EUVD and vendor advisories for the components used.

For critical-infrastructure products the model must include capable adversaries; for consumer products a different model is acceptable (FAQ section 4.1). Write the attacker profile down.

Procedure

1. Draw the data-flow diagram and mark trust boundaries, including the RDPS endpoints on both sides.
2. Enumerate assets per class and attach each to the components and flows that hold or move it.
3. Run the threat method against each flow and asset; record threats with an identifier, the affected component and the attack path.
4. Rate impact on confidentiality, integrity and availability and likelihood from interface exposure, access restriction and user capability (TR-03183-1 RH_RA.1.2 style).
5. Evaluate each risk against acceptance criteria written for this product, not a corporate appetite table (see residual risk below).
6. Select controls and trace each to the Annex I Part I item it serves; populate the applicability matrix.
7. Record residual risk per item and the "other means" relied on, such as user information or intended-use limits.
8. State how Part I point (1) and the Part II processes are applied, as Art 13(3) requires.
9. Sign off, version, and register the update triggers.

Where a companion app or RDPS serves several products, model it once and reference it, as TR-03183-1 section 5.8.1.2 suggests.

The applicability matrix

Art 13(3) requires a statement per item. Art 13(4) and recital 55 require a justification for each item not applied, plus treatment of the residual risk by other means. Keep one row per item and one matrix per product or family.

Item	Applies?	Implementation (control, component, version)	Evidence (test, config export, report, location)	Justification if not applicable and residual-risk treatment
2(a) no known exploitable vulnerabilities				
2(b) secure by default and reset				
2(c) security updates, automatic where applicable				
2(d) access control and unauthorised-access reporting				
2(e) confidentiality				
2(f) integrity and corruption reporting				
2(g) data minimisation				
2(h) availability and DoS resilience				
2(i) limit impact on other networks				
2(j) limit attack surfaces				

Item	Applies?	Implementation (control, component, version)	Evidence (test, config export, report, location)	Justification if not applicable and residual-risk treatment
2(k) exploitation mitigation				
2(l) logging with user opt-out				
2(m) secure erase and transfer				

Expect a heavy justification burden for marking (a), (b), (d) or (l) not applicable. The ETSI drafts treat them as near-universal (see Annex I Part I: essential requirements for product properties). Legitimate cases include 2(g) with no personal data processed, 2(c) automatic installation under the recital 56 carve-out, and 2(m) transfer with nothing transferable.

Residual-risk treatment

Residual risk is judged against "an appropriate level of cybersecurity based on the risks". Guidance C(2026) 5252 paras 156-163 state that cost, commercial strategy and internal risk tolerance "are not relevant". Risk cannot be shifted to users to cover a design shortcoming; an unaddressable risk means the design, functionality or intended purpose must change.

Recital 55 allows residual risk on a non-applicable item to be addressed by other means, such as limiting intended use or informing users. A documented real deployment environment can form part of the intended purpose; a vague disclaimer cannot. Every such reliance must appear in the Annex II document (point 5) so it reaches the user.

Write acceptance criteria per product in terms of impact to users, data and connected systems. A row reading "accepted, business decision" fails. A row reading "accepted: physical access required, documented in Annex II 8(a), re-test on new interface" passes.

Update triggers

Art 13(3) requires the assessment "updated as appropriate during a support period". Part II point 3 requires updates after regular tests and reviews, and BSI TR-03183-1 RH_UPD.1 names the minimum triggers. Wire these into the PSIRT and release processes rather than a calendar.

- A security-relevant release, including any release that changes interfaces, dependencies, the update path or RDPS boundaries.
- A newly known vulnerability in the product or a component (section 8 triage output).
- A newly known threat or attack technique relevant to the product class.
- Results of security tests, reviews or penetration tests that reveal new information.
- A substantial-modification assessment at the release gate (section 5), which re-runs the affected rows only (guidance paras 122-123).

Each update is a new version of the assessment with a change log. Keep old versions, because the technical file must reflect every version placed on the market (Art 13(13)).

Where it lives

The assessment is Annex VII point 3, with the support-period rationale beside it in point 4 (see Conformity assessment and documentation). The BSI TR-03183-1 section 4.8 report structure is a usable container, and section 11 of this guide adopts it. Store the diagrams, threat list, matrix and change log together under version control, linked from the evidence index (section 12).

Worked mini-example

Three rows for a connected device with a companion app and a manufacturer cloud, written to the standard an assessor should see.

Threat and asset	Risk and rating	Item and control	Evidence	Residual risk and treatment
T-07: attacker on the home network replays a captured remote command to the device (functional asset: actuator control)	Integrity high; likelihood medium (remote interface, no physical access needed)	2(f): commands carry a device-bound signature and monotonic nonce; device rejects stale or unsigned commands; rejection logged under 2(l)	Protocol design note v3; negative test NT-12 (replay rejected); log sample L-04	Low; residual depends on device clock integrity, covered by signed time sync; no user action needed

Threat and asset	Risk and rating	Item and control	Evidence	Residual risk and treatment
T-11: factory-default credential reused across units lets an attacker log in to the local admin interface (data asset: admin credential)	Confidentiality and integrity high; likelihood high if defaults exist	2(b) and 2(d): per-unit credential provisioned at manufacture, printed on the unit, forced change at first login; lockout after 10 failures	Provisioning record P-02; firmware config export FC-09 showing no default account; test NT-03	Low; residual is sticker loss, treated by Annex II 8(a) guidance and in-app reset flow
T-19: OSS TLS library in firmware carries CVE listed in EUVD at release candidate time (security asset: TLS stack)	Severity depends on reachability; the vulnerable code path is not compiled in	2(a): reachability analysis shows function excluded by build flags; VEX statement "not_affected" with justification; upgrade scheduled for next security release	SBOM hash S-2026.10; VEX V-031; build-flag evidence BF-02	Accepted as not exploitable in this product (guidance para 218); re-test trigger if library configuration changes

Each row names an item, a control, an evidence identifier and a treatment that is not cost. That is the decision trail authorities and notified bodies will ask for.

The signed assessment closes the Annex I Part I and Article 13 lines in the Requirement checklists tab (checklists 2 and 4).

4. Implementing Annex I Part I: design patterns and acceptance criteria

Each Annex I Part I item below gets a pattern to build, criteria to test and an artefact for the technical file. The legal text, mapping tables and standards state are in Annex I Part I: essential requirements for product properties. Items apply only as the section 3 risk assessment says they do.

Sources are the ENISA Secure by Design and Default Playbook v1.0 principles 4.1 to 4.22 with their "minimum evidence". Draft ETSI EN 304 621 v1.0.4 clauses 5.3 to 5.15 are the second source.

They are joined by draft ETSI EN 304 626 mitigations, EN 18031-1 mechanism families and IEC 62443-4-2 component requirements. The ETSI texts are drafts under public enquiry with no presumption of conformity; EN 18031 is cited under RED only.

Where software and connected devices differ, both are given.

2(a) No known exploitable vulnerabilities

Build a release gate that correlates the release SBOM with the EUVD, NVD and the CISA KEV catalogue and blocks on unresolved exploitable findings. Software products add an update-at-first-use check so vulnerabilities disclosed between placing and installation are closed on first launch (draft EN 304 626 MI-KEVD/MI-KEVA). Devices held in stock need the same behaviour on first boot (draft EN 304 621 Annex G.5.3).

- [ ] Every component in the release SBOM has been matched against EUVD, NVD and KEV within 24 hours of the gate
- [ ] Each open finding has a VEX status with justification or a documented public mitigation
- [ ] All available upstream patches are applied or the exception is recorded with severity, exploitability and impact (guidance paras 235-237)
- [ ] First-use update test passes on a unit built from the release image

Evidence: scan reports, VEX file, gate record with SBOM hash, first-use update test log (Annex VII point 6).

2(b) Secure by default and reset to original state

Ship with no shared credentials, optional services off, approved cryptography only and debug interfaces protected or disabled. Add an onboarding flow that cannot be skipped (Playbook 4.15, 4.16, 4.19; draft EN 304 621 SBD_TECH-1 to -3). Software products enforce this through the installer and first-run wizard.

Devices add per-unit secrets provisioned at manufacture and a hardware or recovery-mode reset to the secure baseline. The reset must wipe user data, settings and credentials, and it survives the tailor-made carve-out (draft EN 304 621 note to SBD_TECH-3).

- [ ] Fresh-install configuration export contains no default account and no listening optional service
- [ ] First-run flow forces credential set-up and, for privileged roles, a second factor

- [ ] Reset test: write data to every store, reset, read back nothing; cloud bindings revoked
- [ ] Any legacy or interoperability protocol is off by default with a user notice and upgrade path (guidance Example 10)

Evidence: default-configuration baseline, interface inventory with default state, provisioning record, reset test record, EN 18031-1 GEC and AUM decision records where RED applies.

2(c) Security updates, automatic where applicable

Build the client side here and the mechanism in section 7. Consumer products install security updates automatically by default, with notification, postponement and a clear opt-out. Managed estates offer scheduling in place of unattended installation (recital 56; draft EN 304 621 SU_UPDATES-7 to -14).

Software products keep OS and application update paths independent. Devices separate firmware from application updates so a security fix never requires a feature image.

- [ ] Default configuration shows automatic security updates enabled, or the recital 56 carve-out is justified in the risk assessment
- [ ] Opt-out and postpone are reachable in at most two steps and are documented in Annex II point 8(e)
- [ ] Security-only release installs without the preceding feature release
- [ ] User sees a notification for each available update with the advisory text

Evidence: Playbook 4.20 minimum evidence (default configuration, release notes showing separable fixes, update tests, user-notification proof).

2(d) Access control and unauthorised-access reporting

Authenticate every interface, including device-to-cloud and management paths. Add role-based authorisation, lockout, session limits and expiring machine credentials (Playbook 4.3, 4.16; EN 18031-1 ACM-1/2, AUM-1 to -6; IEC 62443-4-2 FR1). The reporting half is often missed: the product must surface possible unauthorised access, which draft EN 40000-1-4 slides place in a new control GEC-13.

- [ ] No unauthenticated interface in any product state, confirmed by port and endpoint scans
- [ ] Negative tests show denied access for wrong role, expired session and revoked token
- [ ] Ten failed logins trigger lockout or back-off and an audit event
- [ ] Repeated failures or privilege changes raise a visible alert or report

Evidence: access model, IAM inventory, negative-test results, alert catalogue, audit-log samples.

2(e) Confidentiality

Use TLS 1.3 or equivalent with server authentication, mutual authentication for machine links and no plaintext fallback. Encrypt data at rest with keys held in a secure element, TEE or key-management service (Playbook 4.17, 4.18; EN 18031-1 SCM, SSM, CCK, CRY-1). Choose algorithms from a published catalogue such as the one draft EN 304 621 Annex K references, and record crypto agility.

Devices without a secure element document the compensating key protection.

- [ ] Cryptographic inventory lists every algorithm, mode, key size and library against the chosen catalogue
- [ ] Downgrade and plaintext-fallback tests fail closed
- [ ] Keys are never in firmware images or logs, confirmed by binary scan
- [ ] Data classification table maps each data type to its at-rest and in-transit protection

Evidence: crypto inventory, protocol configuration, negative tests, key-management design.

2(f) Integrity and corruption reporting

Implement verified boot with a hardware or firmware root of trust, signed firmware and software, signed configuration and authenticated commands. Add integrity monitoring that reports corruption (Playbook 4.11, 4.14; IEC 62443-4-2 CR 3.1, 3.4, EDR 3.11 to 3.14). Software products sign packages and configuration bundles and verify at load; devices add anti-tamper and a signed configuration store.

The "report on corruptions" clause needs a user-visible or logged event, not silent repair.

- [ ] Modified image, configuration or command is rejected and an integrity event is logged
- [ ] Boot chain verifies every stage; a tampered stage halts into recovery
- [ ] Key rotation and trust-anchor update are tested without bricking the unit
- [ ] Corruption of stored data is detected and reported to the user or administrator

Evidence: boot-chain description and tests, signature-verification tests, corruption-detection test, tamper evidence.

2(g) Data minimisation and telemetry defaults

Inventory every data item per function and collect only what the function needs. Keep telemetry and analytics off by default with explicit opt-in (Playbook 4.2; draft EN 304 621 DM_RETENTION; draft EN 40000-1-4 DTM-1 to -3). Define retention per data type and strip personal data and secrets from logs.

Where the risk assessment marks 2(g) not applicable because no personal data is processed, the data inventory is the justification.

- [ ] Data inventory for the default configuration lists source, purpose, retention and legal basis where GDPR applies
- [ ] Telemetry is disabled in the default configuration export
- [ ] Log scan finds no personal data or secrets
- [ ] Retention is enforced by code or configuration, not policy alone

Evidence: data inventory, retention schedule, default-configuration export, DPIA cross-reference.

2(h) Availability and DoS resilience

List essential and basic functions, then protect each with rate limiting, resource quotas, early rejection of bad input, watchdogs and graceful degradation. The references are Playbook 4.5 and 4.12, IEC 62443-4-2 CR 7.1 to 7.4 and EN 18031-1 RLM-1. Devices must keep local control working when the backend is unavailable; backends need failover and tested restore.

Draft EN 304 621 AP_HA and the draft EN 40000-1-4 RLM-2 to -6 objectives add recovery, prioritisation and backup.

- [ ] Essential-function list exists with a mitigation per function
- [ ] Load test at the documented ceiling keeps essential functions responsive
- [ ] Backend outage test: device keeps local operation and recovers automatically
- [ ] Restore from backup meets the documented recovery objective

Evidence: essential-function list, stress and recovery test reports, availability-event logs.

2(i) Limiting impact on other networks

Document every network emitter and bound outbound traffic with rate limits and retry back-off. Prevent the product being used as an amplifier or relay (Playbook 4.15; EN 18031-1 TCM-1, NMM-1; IEC 62443-4-2 CR 5.1, 5.2). The JRC-ENISA mapping calls standards coverage "minimal" here, so test it yourself.

Management interfaces accept connections only from known sources where the deployment allows.

- [ ] Emitter inventory lists each outbound destination, protocol, frequency and worst-case volume
- [ ] Amplification factor of every UDP or broadcast service is calculated and below one, or the service is authenticated

- [ ] Retry storms are bounded by exponential back-off with jitter in a backend-outage test
- [ ] External port scan from a separate network segment shows only documented listeners

Evidence: emitter inventory, scan results, amplification calculations, segmentation guidance for Annex II.

2(j) Attack-surface reduction

Enumerate services, ports, protocols and physical interfaces per product state and justify each one (Playbook 4.4; draft EN 304 621 MAS_TECH; EN 18031-1 GEC). Devices disable or lock JTAG, SWD, UART and test pads in production, with fuse or lock-state evidence. The references are draft EN 304 626 MI-PDDI-1 to -4 and IEC 62443-4-2 EDR 2.13.

Software products strip development tooling, debug endpoints and sample configurations from release builds.

- [ ] Interface inventory per state (boot, idle, in use, recovery) with a reason for each exposed interface
- [ ] Production unit shows debug ports locked, verified by attempting a debugger attach
- [ ] Release build contains no debug endpoint, test account or development dependency
- [ ] Default-deny network policy confirmed by scan

Evidence: interface inventory, debug-lock evidence, port scans, hardware photographs (Annex VII point 1).

2(k) Exploitation mitigation

Prefer memory-safe languages for new code. Where C or C++ remains, build with stack protection, ASLR, W^X, control-flow integrity and fortified libraries, and verify the flags on the shipped binary. The references are Playbook 4.5 and 4.9 and draft EN 304 626 TR-SSDD, TR-MSAF and TR-LMII.

Sandbox parsers and network-facing services, separate privileges and zero secrets after use. Devices with a TEE or TrustZone isolate key handling there.

- [ ] Binary hardening scan of the shipped artefact shows every mandated flag present
- [ ] Fuzzing of each external parser runs in CI with memory-error detection and no open crashes at release
- [ ] Network-facing processes run unprivileged in a sandbox or container with a deny-by-default policy
- [ ] Penetration test confirms a compromised service cannot reach keys or the update path

Evidence: compiler-flag and hardening-scan output, fuzzing reports, privilege model, penetration-test report.

2(l) Logging with user opt-out

Log authentication outcomes, privilege and configuration changes, update events and integrity events. Use structured fields with timestamp, actor, action, object and result (Playbook 4.10; IEC 62443-4-2 CR 2.8 to 2.12; draft EN 304 621 MON_LOG). Protect logs from tampering, export them to the user's SIEM, and give the user an opt-out.

Where the opt-out would disable security-essential events, document which events persist and why in the risk assessment and Annex II.

- [ ] Event catalogue exists and every listed event appears in a sample log
- [ ] Logs are tamper-evident and rotated to the documented retention
- [ ] Opt-out control is reachable by the user and its effect is documented
- [ ] No personal data or secrets in log output

Evidence: event catalogue, annotated samples, retention configuration, SIEM forwarding test, opt-out evidence.

2(m) Secure erase and transfer

Provide a factory reset or account deletion that permanently removes all user data and settings, by overwrite or by destroying the encryption key. Cover local storage, credentials and cloud bindings (Playbook 4.7, 4.22; EN 303 645 5.11; IEC 62443-4-2 CR 4.2). Ownership transfer must revoke the previous owner's access.

Where data can be exported, the export runs over an authenticated, protected channel. Draft EN 304 621 does not require transfer support.

- [ ] Write-erase-read test per data type on device, in the app and in the cloud account
- [ ] Previous owner cannot reach the unit or its data after transfer
- [ ] Export requires authentication and is encrypted in transit
- [ ] Decommissioning steps are written into Annex II point 8(d)

Evidence: erase test records, crypto-erase design note, transfer test, Annex II text.

The remote-data-processing boundary

Annex I applies to the product as a whole, including its RDPS modules. Draft EN 304 621 Annex R (draft) adds boundary requirements on both endpoints.

The local side verifies origin, integrity and freshness of what arrives and behaves safely on unavailability. The RDPS side does the same for what the device sends.

The hosting infrastructure stays outside the product and is a supply-chain dependency under Art 13(5). Assurance such as ISO/IEC 27001 or NIS2 evidence is reusable for it (guidance para 207).

- [ ] Each remote function in the section 2 map has an authentication, integrity, confidentiality and availability control on both ends
- [ ] Device behaviour on backend loss is defined and tested per function
- [ ] RDPS modules appear in the SBOM, the risk assessment and the test reports
- [ ] The product connects only to documented remote services

Evidence: remote-function map, boundary test results, RDPS deployment and configuration records.

The integrator pattern for components and MCUs

A separately sold chip or module is a product in its own right. Items 2(b), 2(l) and 2(m) cannot be fully met at silicon level.

Vendor papers from TI and Microchip (vendor material) describe a split. Draft EN 304 621 Annex K and EN 304 626 MI-PDDI-1 formalise the same split.

The component vendor documents root of trust, debug-lock states, key provisioning and integration assumptions in Annex II point 8(f). The integrator owns product-level defaults, reset, logging, the risk assessment and the technical file.

As an integrator, treat each vendor's integration assumptions as requirements and test them on your board. Record the vendor documentation reviewed in the due-diligence record (section 9).

Each item's evidence artefact is the entry for checklist 2, Annex I Part I, in the Requirement checklists tab.

5. Secure development lifecycle integration

The CRA is satisfied by evidence a pipeline produces, so add gates to the existing lifecycle rather than a parallel compliance process. Teams already running IEC 62443-4-1, NIST SSDF or OWASP SAMM add rather than replace. The additions are the Annex I applicability matrix, SBOM depth and quality, the per-release security-delta check, declared support periods and the Art 14 clock.

The programme view is in Engineering compliance programme; this section specifies the gates.

The gates to add

Gate	Where	What it checks	Record produced
Design review	Before implementation of a feature or product	Threat model updated for the change; applicability matrix rows affected; RDPS boundary unchanged or re-mapped	Design review minute referencing threat identifiers
Component intake	On adding or upgrading a dependency	Need statement, maintenance signals, licence, EUVD and OSV history, exit plan (section 9)	Due-diligence record (Art 13(5))
Code review	Every merge	Security-relevant change flagged; secure-coding checklist; no secrets or debug endpoints	Review approval with security label
Static and dynamic analysis	Every release candidate	SAST with critical and high findings resolved or risk-accepted; DAST on exposed interfaces; fuzzing of external parsers with memory-error detection	Scan reports attached to the build
Dependency and SBOM check	Every build	SBOM generated from the artefact (section 6); quality score; vulnerability match against EUVD, NVD, GHSA and OSV; VEX for non-reachable findings	Signed SBOM, VEX, scan output

Gate	Where	What it checks	Record produced
Release gate	Before tagging a release	Tests complete; SBOM hash recorded; known-exploitable check against EUVD, NVD and the CISA KEV catalogue; secure-default configuration verified; security-delta assessment; substantial-modification decision; documentation delta	Release security gate record
Post-release	Continuous	Monitoring feeds, PSIRT triage, risk-assessment update triggers (section 3)	PSIRT case files, assessment versions

The release security gate record is the single most useful artefact in the file. It ties a shipped artefact to its tests, SBOM, exploitability decision and placing decision. That is what a notified body or market surveillance authority will ask to see first.

The security-delta assessment

Every release answers whether it is a substantial modification. A substantial modification is a new placing on the market with its own declaration and support period (see Conformity assessment and documentation).

Use the four questions from guidance C(2026) 5252 para 110: new threat vectors, new attack scenarios, changed likelihood, changed impact. Four negative answers mean not substantial.

Security updates that reduce risk and keep the intended purpose are "generally not" substantial (para 108). Features foreseen in the risk assessment are not substantial. Small features adding unassessed risk, such as persistent login tokens or unencrypted log export, can be (paras 103-108, Examples 40-48).

Record the answers, the assessor and the decision on the gate record. Route a positive decision to section 11 for a new declaration and to section 12 for the notified body where one is involved.

Mapping to existing frameworks

Framework	What it already covers	What the CRA adds
IEC 62443-4-1	Security management, requirements, secure design, implementation, verification, defect management, update management; covers 36 of 42 SSDF tasks fully (ISAGCA)	Fixed Art 14 clocks, SBOM depth and fields, Annex II user information, declared support periods, separation of security from feature updates
NIST SSDF (SP 800-218)	Prepare, protect, produce, respond practices	Post-release practices that 62443-4-1 has and SSDF lacks; the Annex I applicability trail; EU reporting
OWASP SAMM	Maturity measurement across governance, design, implementation, verification, operations	Nothing CRA-specific; use it to score the gates above and show improvement over time
ISO/IEC 27001 with BSI TR-03183-H	ISMS extended to design, development, production and vulnerability handling; controls 5.7, 5.8, 8.8, 8.25, 8.29, 8.32 refined	The Module H route; see section 12

The ENISA Playbook v1.0 references OWASP SAMM for maturity and gives per-principle release gates and evidence lists that fit the table above. None of these frameworks is cited under the CRA and none gives presumption of conformity.

Testing cadence: threat-driven, not calendar-driven

Part II point 3 requires "effective and regular tests and reviews". Guidance paras 238-240 read "regular" as reviewing whether new threats or vulnerabilities require the test set to change, then executing.

Repeating an unchanged campaign at fixed intervals is not the obligation. Proportionality to the risk profile is explicit, and a review finding no new input needs no new tests.

"Regular" must still be shown. Keep a test plan per product with a review log: date, inputs reviewed, decision, tests added or re-run, results. Inputs include EUVD and vendor advisories, threat reports and product changes.

Regression tests after every modification remain mandatory in that reading. Quarterly review entries, each citing the intelligence considered, demonstrate regularity without treating calendar repetition as the obligation.

Minimum content of the plan: SAST on every release candidate, fuzzing of every external parser and DAST or API testing on every exposed interface. Add a penetration test on the product and its RDPS before first placing and after any substantial modification, plus re-tests triggered by PSIRT findings.

Evidence capture in CI

Generate evidence where the work happens and sign it, so the technical file is assembled rather than written. The ENISA Playbook section 5.1 argues machine-processable attestations keep documentation current, while cautioning that a self-issued attestation is not proof of security.

1. Emit SAST, DAST and fuzzing results as SARIF or equivalent and store them with the build identifier.
2. Generate the SBOM at build and attach it as an attestation bound to the artefact digest (section 6).
3. Sign release artefacts and attestations with Sigstore cosign or GitHub artefact attestations. Keep signing keys out of the pipeline runner where an HSM-backed signer exists (section 7).
4. Record the gate decisions as a structured file committed with the release tag.
5. Pin third-party CI actions to commit hashes. One vendor-adjacent guide cites the March 2026 compromise of a popular scanner action as the reason (CRA Decoded, vendor-adjacent).

```
# release-gate job (GitHub Actions excerpt)
- name: Verify SBOM attestation
  run: cosign verify-attestation --type cyclonedx \
       --certificate-identity-regexp '^https://github.com/acme/.*' \
       --certificate-oidc-issuer https://token.actions.githubusercontent.com
\
       ghcr.io/acme/thermostat-fw@${{ steps.build.outputs.digest }}
- name: Known-exploitable check
  run: grype sbom:sbom.cdx.json --fail-on high --only-fixed=false \
       && ./kev-check.sh sbom.cdx.json kev.json
- name: Record gate
  run: ./gate-record.sh --sbom-sha512 "$(sha512sum sbom.cdx.json | cut -d' '
-f1)" \
       --delta "$DELTA_DECISION" --out gate-${{ github.ref_name }}.json
```

The gate record travels with the release into the technical file and into the evidence index (section 12).

Sample release-gate checklist

- [ ] Threat model and applicability matrix reviewed for this release; affected rows updated or confirmed
- [ ] Code review complete with every security-relevant change labelled and approved
- [ ] SAST: no open critical or high finding without a recorded risk acceptance
- [ ] Fuzzing and DAST run on changed parsers and interfaces; no open crash or exploitable finding
- [ ] SBOM generated from the shipped artefact, quality-checked, signed; SHA-512 recorded here
- [ ] Known-exploitable check against EUVD, NVD and KEV complete; every finding fixed, mitigated with a VEX justification, or release-blocked
- [ ] Secure-default configuration export matches the baseline; no default credentials, telemetry off, debug interfaces locked
- [ ] Update package signed with the release key; anti-rollback version incremented; first-use update test passed
- [ ] Security-delta assessment answered on the four guidance questions; substantial-modification decision recorded with assessor
- [ ] Separation check: security fix shipped separately from features, or the bundling exception recorded (FAQ section 4.3)
- [ ] Documentation delta: Annex II text, advisory, release notes and support-period statement updated
- [ ] Declaration decision: existing declaration covers this release, or a new declaration is triggered
- [ ] Gate record signed by the release manager and product security owner

Legacy designs

Products designed before 11 Dec 2027 but placed after may rely on the Art 13(2) risk assessment and technical documentation to show appropriate security. No redesign and no recreated historical design or test documentation is needed (guidance paras 33-39, Example 12). Conformity assessment, the declaration, the CE marking and Part II process evidence are still required.

For such a product, the gates above apply from the next release onward. Build the applicability matrix against the product as it exists and run the current tests.

State in the file which design-phase evidence is contemporary and which rests on the assessment. Any later substantial modification brings the modified parts under the full set of gates.

The gate records are the evidence for checklists 2, 3 and 4 in the Requirement checklists tab.

6. SBOM pipeline

Generate the SBOM at build time from the artefact you ship, not from the manifest you think you built. The legal minimum is one machine-readable SBOM per product covering at least top-level dependencies. The de facto engineering profile is BSI TR-03183-2 v2.1.0, non-binding but the strictest widely referenced European specification.

The legal position and the missing Art 13(24) implementing act are covered in Annex I Part II: vulnerability handling and lifecycle duties.

Generation from the shipped artefact

Run generation immediately after compilation or image assembly while the build context exists, so transitive dependencies are captured (ENISA SBOM advisory v1.10 section 4.1). A manifest-only SBOM misses vendored code, statically linked libraries and binaries copied into images. One vendor teardown found an embedded web server with a 2002 CVE that way (Finite State, vendor).

Where the build system cannot see a component, scan the final artefact and merge.

Artefact type	Primary generator	Supplement
Container image	Syft or Trivy on the image digest	cdxgen for application manifests inside the image
Language package (JVM, npm, Go, .NET)	cyclonedx-maven-plugin, @cyclonedx/cyclonedx-npm, cyclonedx-gomod, CycloneDX dotnet tool	Syft on the packaged output
Embedded Linux firmware	Yocto or Buildroot built-in SBOM generation	Binary SCA of the final image for blobs and vendored code
RTOS or bare-metal firmware	Zephyr "west spdx" or build-system plugin	Linker map cross-check for statically linked libraries

Artefact type	Primary generator	Supplement
Mobile app	cdxgen or platform plugin on the signed bundle	Store-delivered SDK versions recorded per release
RDPS backend	Same as container or language package, per deployable service	Infrastructure left out; recorded as a dependency in the file

Treat RDPS modules as part of the product and give them SBOMs. The hosting platform is a supply-chain dependency, not an SBOM entry (guidance para 205).

Format and version

Produce CycloneDX 1.6 or later, or SPDX 3.0.1 or later, in JSON or XML (TR-03183-2 section 5). Favour one format natively rather than converting; conversion loses fields. CycloneDX 1.7 (October 2025) adds native VEX metadata and CSAF linkage per ENISA's comparison table, which helps with the separation rule below.

Required fields per component

TR-03183-2 section 5.2 requires, per component: creator, name (else filename), version (SemVer or CalVer recommended), filename and dependencies with completeness marked. It also requires distribution licences, the SHA-512 hash of the deployable component, and the executable, archive and structured properties. Add where they exist: source-code URI, deployable URI, CPE and purl, original licences.

At SBOM level record creator (email or URL), timestamp in UTC and an SBOM URI where one exists.

Default generator output does not emit the BSI filename, executable, archive and structured properties. Post-process with BSI's registered CycloneDX taxonomy and validate (CRA Decoded, vendor-adjacent). The CISA 2025 and 2026 minimum elements add component hash algorithm, licence, tool name and generation context.

ENISA's advisory carries a BSI-to-CISA field mapping. Recording tool name and generation context costs little and satisfies both.

```
{
  "type": "library",
  "bom-ref": "pkg:generic/mbedtls@3.6.2?file=libmbedtls.a",
  "supplier": { "name": "Trusted Firmware project", "url":
["https://www.trustedfirmware.org"] },
  "name": "mbedtls",
  "version": "3.6.2",
  "purl": "pkg:github/Mbed-TLS/mbedtls@v3.6.2",
  "hashes": [{ "alg": "SHA-512", "content": "9f2c...e41a" }],
  "licenses": [{ "license": { "id": "Apache-2.0" } }],
  "properties": [
    { "name": "bsi:filename", "value": "libmbedtls.a" },
    { "name": "bsi:executable", "value": "false" },
    { "name": "bsi:archive", "value": "true" },
    { "name": "bsi:structured", "value": "false" },
    { "name": "bsi:dependencies:complete", "value": "true" }
  ]
}
```

Property names shown illustrate the BSI taxonomy pattern; use the identifiers BSI publishes for its CycloneDX namespace.

Depth

Recurse down every dependency path at least to the first component outside your delivery scope, and include it. TR-03183-2 section 5.1 calls this the "delivery item SBOM".

List multiple instances of the same component with different metadata separately. You may reference a component's own SBOM instead of merging it only if that SBOM is itself compliant.

Mark completeness explicitly and declare known unknowns, distinguishing unknown from redacted.

The CRA floor is top-level dependencies. The OpenChain CRA checklist (community draft) ties the depth decision to the ability to make a 24-hour exploited-vulnerability determination. Record the depth decision and its rationale in the technical file.

No vulnerability data in the SBOM

The SBOM is static inventory; vulnerability status changes daily. TR-03183-2 section 8.1.14 states the SBOM "MUST NOT contain vulnerability information" and recommends CSAF, with VEX as a profile, for that exchange. Keep three artefacts per release: the SBOM, a VEX document with a justified status per finding, and CSAF advisories for fixed vulnerabilities (section 8).

A "not_affected" VEX statement with a reachability justification is also evidence that no Art 14 report was due (guidance para 218).

Quality, signing, storage and retention

1. Validate the schema with the CycloneDX CLI or the SPDX validators.
2. Score with sbomqs, which has a TR-03183-2 check, and fail the build below your threshold; record the score.
3. Sign or attest the SBOM bound to the artefact digest with Sigstore cosign or GitHub artefact attestations. Record the SHA-512 of the SBOM in the release gate record (section 5).
4. Store the SBOM, VEX, validation output, signature and generation log with the release artefacts. Use a dedicated location and a naming convention per product and version.
5. Retain for at least 10 years after placing or the support period, whichever is longer. The SBOM is part of the Annex VII technical documentation (Art 13(13)).

```
# sbom job (GitHub Actions excerpt)
- name: Generate SBOM from image
  run: syft ghcr.io/acme/thermostat-fw@${DIGEST} -o cyclonedx-json@1.6 >
sbom.cdx.json
- name: Enrich to BSI fields
  run: ./bsi-enrich.py sbom.cdx.json --hash sha512 --mark-completeness
- name: Validate and score
  run: cyclonedx validate --input-file sbom.cdx.json && sbomqs score
sbom.cdx.json --category bsi-v2 --min 8.0
- name: Attest
  run: cosign attest --yes --type cyclonedx --predicate sbom.cdx.json
ghcr.io/acme/thermostat-fw@${DIGEST}
- name: Upload to Dependency-Track
  run: curl -X PUT "$DT_URL/api/v1/bom" -H "X-Api-Key: $DT_KEY" \
       -F "projectName=thermostat-fw" -F "projectVersion=${GITHUB_REF_NAME}"
-F "bom=@sbom.cdx.json"
```

Continuous monitoring

Upload every release SBOM to Dependency-Track or an equivalent that polls NVD, GHSA and OSV. Add an EUVD watch, because the Commission treats EUVD listing as making a vulnerability "known" (guidance paras 233-234).

Route new matches to PSIRT triage (section 8) with product, version and support status attached. The Art 14 exploitation determination then starts the same day.

Keep monitoring running for every version still inside its support period, including versions no longer sold.

Who receives the SBOM

The SBOM lives in the Annex VII technical documentation (point 2(b)). It goes to a market surveillance authority on reasoned request (point 8), or under Art 13(25) for an ADCO dependency assessment. Recital 77 says manufacturers need not publish it; Annex II point 9 makes user access optional and, if offered, requires saying where.

Decide per product and record the decision; many B2B customers will ask for it contractually regardless.

Tooling landscape

ENISA's advisory section 2.2.3 lists generation tools (Syft, Trivy, cdxgen, and build plugins for Maven, Gradle, npm, Go, .NET, Linux and Zephyr). It lists validation (CycloneDX CLI, SPDX tools), quality (sbomqs, sbom-scorecard) and signing (cosign, GitHub attestations). Vulnerability management covers Grype, Trivy, Dependency-Track, OWASP Dependency-Check and dep-scan.

ENISA's SBOM State of Play 2026 (334 responses) found 44% of respondents using CycloneDX, 29% SPDX and 39% generating at build. Completeness was the top challenge at 62%, which is the manifest problem this section exists to prevent.

The signed SBOM and VEX per release close the SBOM lines of checklist 3, Part II, in the Requirement checklists tab.

7. Secure update mechanism

The update mechanism keeps every other Annex I item true after shipment, so design it as a security product in its own right. It serves Part I items 2(c) and 2(f) and Part II points 2, 7 and 8. The legal detail is in Annex I Part I: essential requirements for product properties and Annex I Part II: vulnerability handling and lifecycle duties.

ENISA's draft Technical Advisory on Secure Update Mechanisms (draft v0.1 of May 2026; v0.6 consulted to 10 Jul 2026) is the reference used here. It is technology-agnostic and "consistent with" TUF, Uptane and NIST SP 800-40.

Architecture

Element	Pattern	Why
Signing keys	Offline root key; online operational signing key; both in an HSM or cloud KMS with role separation between build, release approval and key custody	ENISA section 4.1 (secure signing, key protection, separation of duties); draft EN 304 621 threat list names revoked and compromised signing keys
Metadata	TUF-style roles (root, targets, snapshot, timestamp) or Uptane director and image repositories for fleets; metadata carries version, expiry and a monotonic counter	Freshness and anti-rollback (ENISA 4.2, 4.3); TUF and Uptane are the named patterns
Transport	TLS to a trusted source, with trust placed in the signature not the download location; controlled redirects	ENISA 4.2 trust model
Verification	Verify signature, applicability (model, hardware revision, current version) and freshness before any write to the active partition	ENISA 4.3; draft EN 304 621 SU_UPDATES-4 to -6
Anti-rollback	Reject any image whose counter is below the installed one; an intentional downgrade needs explicit authorisation and an auditable event	ENISA 4.3; draft EN 304 621 SU-6
Install	Atomic A/B slots or transactional package install; power loss at any point leaves a bootable, secure unit; recovery image retained	ENISA 4.3, 4.4; Playbook 4.20 release gate "failed updates do not leave the system insecure or unusable"
Observability	Record start, finish, outcome and failure reason per unit; secure logging; corruption handling; trust-anchor recovery path	ENISA 4.4; draft EN 304 621 SU-12

For software products the same pattern applies with package signatures, a signed manifest and transactional installation. For app-store distribution the store's signing is the transport; the manufacturer still verifies and logs applicability and version on first run.

Default-on automatic security updates

Part I item 2(c) requires, where applicable, automatic security updates installed within an appropriate timeframe and enabled by default. It adds a clear and easy opt-out, user notification and temporary postponement; consumer products are the primary case (recital 56). Implement a check-and-install cycle that runs unattended and notifies the user with the advisory text.

Allow postponement for a bounded period. Let the user disable automatic installation in a clearly labelled setting documented in Annex II point 8(e).

Managed estates implement "where applicable" through scheduling rather than unattended installation. Maintenance windows, staged rollout and an administrator approval step are the pattern (draft EN 304 621 Annex G on cluster and MDM-managed deployments). The product must still notify and must still make the update available without delay.

Recital 56 carves out products primarily intended as components and products in professional, critical or industrial environments where users would not expect automatic updates. Claim the carve-out only in the risk assessment row for 2(c), with the deployment context as justification, and keep notification and timely availability regardless. A consumer device sold through a professional channel does not qualify by sales channel alone.

Separating security from functionality updates

Part II point 2 requires security updates provided separately from functionality updates "where technically feasible". Run maintenance branches per supported version with a security-only hotfix channel, and keep feature releases on a separate train.

The Commission FAQ v1.4 section 4.3 gives the examples. A certificate-validation fix ships alone; bundling is defensible where the fix needs a functional change, such as a stricter parser. It is also defensible where disabling the vulnerable interface is itself the fix.

Record every bundling decision with the reason on the release gate (section 5). A device with one monolithic firmware image can still separate by cutting a security-only image from the maintenance branch. The exception is rare and must be argued per case.

Advisory messages with each update

Part II point 8 requires security updates "accompanied by advisory messages" with the action users should take. Attach a short advisory to each security update: what was fixed, affected versions, severity and any restart or configuration step. Link it to the full CSAF advisory (section 8).

Devices show it in the app or admin interface; software shows it at install time and in release notes.

Availability for 10 years and public archives

Each security update must remain available for at least 10 years after issue, or the rest of the support period if longer (Art 13(9)). Design the update repository as a long-lived signed-artefact store with immutable storage and metadata that survives key rotation. Budget for it beyond the product's commercial life.

Art 13(11) permits public archives of old versions if users are "clearly informed in an easily accessible manner" of the risks. Put a warning banner on every archive page and in the package metadata.

The latest-version rule

Where successive substantially modified software versions are placed on the market, Art 13(10) allows patching only the latest version. The condition is that users can upgrade free of charge without additional hardware or infrastructure costs. Guidance paras 129-131 exclude normal operational effort from "additional costs" and include mandatory new hardware.

Maintain a version-support matrix stating, per version, whether it receives fixes, the free upgrade path and the end-of-support month and year. The CVD policy and information sharing continue for all versions.

Update at first use for stock units

Units sit in warehouses and on shelves while vulnerabilities are disclosed. Draft EN 304 621 SU_UPDATES-3 (draft) expects the product to attempt installation of security updates released since placing at first use. Draft EN 304 626 frames item 2(a) "at first use" with the same mitigation.

Build the first-boot flow to check for and install security updates before onboarding completes. Document a manual path where no connectivity exists at first use.

Design note contents

The Annex VII technical documentation must describe "the technical solutions chosen for the secure distribution of updates" (point 2(b)). Write one update design note per product or family. Cover trust model and key hierarchy, metadata and anti-rollback, transport and sources, verification and installation flow, recovery and observability.

Add default behaviour and user controls, release trains and separation policy, repository retention and the version-support matrix. Reference the test records below.

Acceptance tests

- [ ] Unsigned, wrongly signed and expired-metadata images are rejected and logged
- [ ] An image with a lower rollback counter is rejected; an authorised downgrade produces an audit event
- [ ] Power loss injected at each stage of install leaves a bootable unit on the previous or new image, never a broken one
- [ ] Recovery image restores a unit after a corrupted active slot
- [ ] Factory-fresh unit with the release-time image installs the latest security update before onboarding completes
- [ ] Default configuration has automatic security updates enabled, or the recital 56 carve-out is justified in the risk assessment
- [ ] Notification, postponement and opt-out work and match the Annex II 8(e) text
- [ ] A security-only release installs on the maintenance branch without the latest feature release
- [ ] Every update event appears in the device log with outcome and reason
- [ ] Signing key rotation and trust-anchor update succeed on fielded units without manual intervention
- [ ] Update server test from a separate network confirms TLS, no plaintext fallback and controlled redirects
- [ ] Archive page for an unsupported version shows the risk warning before download

Keep the test records with the design note; they are Annex VII point 6 evidence and feed the evidence index in section 12.

The design note and test records serve checklist 2 (item 2(c)) and checklist 3 (points 7 and 8) in the Requirement checklists tab.

8. Vulnerability handling and coordinated disclosure

Run one PSIRT process from intake to disclosure, and make the Art 14 exploitation decision a step inside it rather than a separate committee. Part II points 2, 4, 5 and 6 and Art 13(6) and 13(17) set the obligations. The legal detail and the standards state are in Annex I Part II: vulnerability handling and lifecycle duties.

This section is the operating procedure. It is built on BSI TR-03183-3 v1.0.0 (non-binding) and ENISA's SME Vulnerability Kit (consultation draft, October 2026).

Roles

Keep the PSIRT (products) distinct from the CSIRT (own infrastructure), each with a functional mailbox and OpenPGP key. Split the roles across several people unless you are a microenterprise (TR-03183-3 section 4.3.1). Name a triage coordinator, an analyst per product line, a remediation lead and an incident commander.

The incident commander can declare awareness and file the early warning without legal sign-off; legal reviews the 72-hour and final reports. The FIRST PSIRT Services Framework v1.1 gives the full service catalogue.

Intake

Offer three channels and monitor all of them daily (TR-03183-3 recommends automated reachability tests).

1. `/.well-known/security.txt` per RFC 9116 over HTTPS with the ENISA profile. Contact (preferred method first) and Expires (at most 12 months ahead) are mandatory. Encryption, Policy, Canonical, Acknowledgments, Preferred-Languages and an OpenPGP signature are recommended, plus a CSAF field pointing to the provider metadata (BSI section 4.2.8).
2. A web form that allows anonymous submission, carries no third-party scripts or tracking and logs minimally. It exists in English and is linked from the home page (TR-03183-3 sections 4.3.3 to 4.5).
3. A non-automated channel, because Art 13(17) says the single point of contact "shall not limit such means to automated tools". A monitored mailbox or phone line beside any chatbot satisfies recital 63.

The intake must accept reports about third-party components in the product, not only your own code (Part II point 6). Publish the same contact in Annex II point 2.

```
# https://www.example.com/.well-known/security.txt
Contact: mailto:psirt@example.com
Contact: https://www.example.com/security/report
Expires: 2027-10-01T00:00:00.000Z
Encryption: https://www.example.com/security/psirt-pgp.asc
Preferred-Languages: en, de
Canonical: https://www.example.com/.well-known/security.txt
Policy: https://www.example.com/security/cvd-policy
Acknowledgments: https://www.example.com/security/hall-of-fame
CSAF: https://www.example.com/.well-known/csaf/provider-metadata.json
```

Sign the file with the PSIRT key, check it quarterly and renew before Expires; expired contacts head ENISA's "common mistakes" list.

Acknowledgement and response targets

No legal text sets a number. BSI TR-03183-3 section 4.4 asks for a non-automated response within 5 working days and detailed feedback within 10 working days. It also says no single analyst may close a report.

ENISA's kit footnote 7 reports that draft prEN 40000-1-3 caps acknowledgement at 7 calendar days. That figure is second-hand and the standard is not yet published. Set your CVD policy targets at or inside those numbers and measure them.

Triage and severity

Open a case for every report and every monitoring hit (section 6). Fields: source and intake time in UTC; product, versions and support status; component and reachability analysis; affected functionality; severity with CVSS vector; exploitation evidence. Add awareness timestamp if declared, remediation decision, user information, upstream action and regulatory routing.

One vendor case-file schema of this shape is published by SCHUTZWERK (vendor). Document "not reportable" outcomes with the same rigour as reportable ones.

Severity drives internal SLAs by tier; write them down because "without delay" is nowhere quantified.

Reachability comes first. A component CVE whose code is not compiled in or not reachable is not exploitable in your product. It gets a VEX "not_affected" statement (guidance para 218).

The exploitation determination

Every report and every monitoring hit is checked for active exploitation immediately, because Art 14 runs from awareness. Ask three questions for a component finding: is the vulnerable code contained, is it reachable, is it actually exploited in this product. Reliable evidence of malicious exploitation is the test, not a published exploit or a scanner hit (Art 3(42)).

Researcher and bug-bounty findings without exploitation evidence are not actively exploited vulnerabilities (Commission FAQ v1.4 section 5).

When the incident commander judges there is "a reasonable degree of certainty" of exploitation, record the UTC awareness timestamp in the case. Hand the product data pack to the reporting runbook (section 10). The rest of the PSIRT process continues in parallel; remediation does not pause the clock.

Remediation options

The FAQ confirms the CRA does not require a patch for every vulnerability; the remedy is risk-based. Options are a security update on the separate security train (section 7), or a published mitigation such as disabling a feature or changing configuration. Documentation updates suit low risks, such as a debug interface needing physical access; component replacement suits a maintainer who will not fix.

Where no fix exists for an exploited vulnerability, publish the threat and temporary measures without details that help attackers.

Record the decision, the reasoning on severity, exploitability and impact, and the user information issued. Update the risk assessment row (section 3) when the finding changes the threat picture.

Disclosure and advisories

Once a fix is available, publish a human-readable advisory and a CSAF 2.0 document (ISO/IEC 20153:2025). Both carry the CVE and EUVD identifiers, affected and fixed versions, severity with CVSS, impact, remediation and timeline. The basis is Part II point 4 and ENISA kit section 3.3.

Maintain a public advisory index and a CSAF provider with `provider-metadata.json`.

Delay is permitted only in duly justified cases until users could patch; record the justification. BSI's default is disclosure within 90 days, extendable once by 90 days with the national CSIRT, at least on the EUVD. Those are BSI figures, not law.

```
{
  "document": {
    "category": "csaf_security_advisory",
    "csaf_version": "2.0",
    "publisher": { "category": "vendor", "name": "Example GmbH", "namespace":
"https://www.example.com" },
    "title": "Replay of remote commands in Thermostat T200 firmware",
    "tracking": {
      "id": "EX-SA-2026-004", "status": "final", "version": "1",
      "initial_release_date": "2026-11-12T09:00:00Z", "current_release_date":
"2026-11-12T09:00:00Z",
      "revision_history": [{ "number": "1", "date": "2026-11-12T09:00:00Z",
"summary": "Initial" }]
    }
  },
  "product_tree": { "branches": [{ "category": "product_name", "name":
"Thermostat T200 firmware",
    "branches": [
```

```
      { "category": "product_version_range", "name": "<2.4.1", "product": {
"name": "T200 fw <2.4.1", "product_id": "T200-FW-LT-2.4.1" } },
      { "category": "product_version", "name": "2.4.1", "product": { "name":
"T200 fw 2.4.1", "product_id": "T200-FW-2.4.1" } }
    ] }] },
  "vulnerabilities": [{
    "cve": "CVE-2026-XXXXX",
    "ids": [{ "system_name": "EUVD", "text": "EUVD-2026-XXXXX" }],
    "product_status": { "known_affected": ["T200-FW-LT-2.4.1"], "fixed":
["T200-FW-2.4.1"] },
    "scores": [{ "cvss_v3": { "version": "3.1", "baseScore": 7.5,
"baseSeverity": "HIGH",
      "vectorString": "CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N" },
"products": ["T200-FW-LT-2.4.1"] }],
    "remediations": [{ "category": "vendor_fix", "details": "Install firmware
2.4.1 via automatic update or the app.",
      "product_ids": ["T200-FW-LT-2.4.1"] }]
  }]
}
```

For component findings that do not affect the product, publish a VEX document with `product_status.known_not_affected` and a justification flag. For the exact label vocabulary consult the OASIS CSAF 2.0 specification, which this guide does not reproduce. BSI TR-03183-2 and ENISA both place vulnerability status in CSAF or VEX, never in the SBOM (section 6).

Upstream reporting and fix sharing

Art 13(6) requires reporting a vulnerability found in an integrated component to its maintainer and sharing any fix you develop, machine-readable where appropriate. Guidance C(2026) 5252 section 9.2.1 (paras 222-229) sets the mechanics.

Report only the integrated version through the maintainer's CVD channel. Check databases, advisories and issue trackers first to skip reports the maintainer already knows about.

Share fixes in verifiable, licence-compatible form following the project's contribution rules. No duty exists where there is no maintainer, and none that the fix is merged. Record each upstream action in the case file; section 9 covers forks and patches.

Records

Keep the case file, the awareness decision, the VEX and CSAF documents, upstream reports and user notifications for 10 years or the support period. Art 13(7) requires systematic documentation and Annex VII point 2(b) requires evidence of the

vulnerability-handling process. Report quarterly on acknowledgement and response times, open cases by severity and disclosure timeliness.

A Module B notified body audits this process periodically (Annex VIII Module B point 8).

CVD policy

Publish the policy at the URL named in security.txt and Annex II point 2, and review it yearly. Build it on the ENISA kit's ten sections.

They are commitment, scope, how to report, testing rules, report information, what to expect, safe harbour, disclosure timeline, recognition and data protection. The disclosure timeline needs an accelerated path for actively exploited vulnerabilities.

Name the coordinating CSIRT the manufacturer reports to and offer the anonymous route through it (recital 76). The ENISA kit and BSI TR-03183-3 both provide templates. The kit's advisory template and "common mistakes" table are worth adopting as they stand, noting that the kit is a consultation draft.

The policy, security.txt, case files and advisories close the Part II and Article 13 lines in checklists 3 and 4 of the Requirement checklists tab.

9. Open-source components and open-source products

Treat every open-source component as a supplier you cannot contract with, and every open-source product you sell as a product like any other. Art 13(5) requires due diligence on third-party components, expressly including FOSS never placed on the market. Art 13(6) requires upstream reporting and fix sharing, and Annex I Part II(1) puts every component in the SBOM.

The legal position on who is caught, stewards and attestations is in Open-source software; this section is the engineering procedure.

Component selection due diligence

Run a component intake gate before a dependency enters the product, scaled to the component's risk (recital 34).

The Commission FAQ v1.4 lists acceptable actions. They include software composition analysis, sandboxing critical components, reviewing the component's SBOM and support period, and checking its intended purpose fits yours. It adds assessing the supplier's posture and testing by fuzzing or penetration testing.

Guidance C(2026) 5252 section 7.3 frames due diligence as defining what the product needs from the component. That need is then verified by documentation, assurance evidence or tests.

Field	What to record	Signal sources
Need statement	The function the product takes from the component and the security properties it relies on	Architecture; applicability matrix rows served
Maintenance signals	Release cadence, time to fix past CVEs, active maintainers, security policy present, bus factor	Repository history; SECURITY.md; OpenSSF Scorecard; Security Insights
Assurance	OpenSSF Scorecard result; OSPS Baseline level claimed or assessed; any published self-attestation; conformity evidence where the component is itself a CRA product	OSPS Baseline (41 requirements, 3 levels); Scorecard
Licence	SPDX identifier; compatibility with your distribution; obligations triggered by shipping fixes upstream	Licence scanner output
Vulnerability history	Open and historical entries in EUVD, NVD and OSV; whether fixes shipped in supported branches	EUVD, NVD, OSV, GHSA
Support horizon	Upstream support period against your declared support period; what happens at upstream end of life	Project release policy
Exit plan	Replacement candidates; effort to swap; isolation measures if it must stay	Architecture review
Decision	Approved, approved with conditions, rejected; owner; date; review trigger	Intake gate record

A component whose upstream support ends inside your support period needs an exit plan at intake. The FAQ requires you to replace or patch an unsupported component yourself. Recital 58 asks that dependencies on high-risk suppliers appear in the risk assessment; link the intake record to section 3.

Inventory and monitoring

Every component, including transitive ones to the depth chosen in section 6, appears in the release SBOM with purl, version, licence and hash. Dependency-Track or an equivalent watches NVD, GHSA, OSV and the EUVD for every supported version and feeds PSIRT triage (section 8). Pin versions and verify hashes or signatures at build; a lockfile without hash verification is an inventory, not a control.

Forking and patching strategy

When upstream will not fix in time, fix it yourself and share the fix. Keep patches as discrete commits on a vendor branch tracking upstream, named by CVE or EUVD identifier. The SBOM can then record pedigree and the patch can be dropped when upstream catches up.

Avoid silent forks. The Linux Foundation 2026 report cites LF's 2025 Open Source ROI survey (n=236): an average of 86 private forks per organisation at about 60 hours per fork per release cycle. Its own 2026 survey finds 51% of manufacturers rely passively on upstream for fixes.

For each fork record the upstream commit, the patches carried, the reason, the owner and the re-sync cadence. A fork that drifts from upstream becomes your component with your vulnerability-handling burden.

Contributing fixes upstream

Art 13(6) requires sharing the code or documentation of a fix with the maintainer, "where appropriate in a machine-readable format". Guidance section 9.2.1 (paras 222-229) sets the mechanics. Report the vulnerability through the project's CVD channel for the version you integrate, after checking databases, advisories and issue trackers to avoid duplicates.

Submit the fix as a patch or pull request in the project's format under a compatible licence and contributor agreement. There is no duty that it is merged and no duty to accept the project's own fix.

Contributing code to a project you do not control does not make you its manufacturer or steward (recital 18; guidance paras 48-49, 85-86). Log every upstream report and contribution in the PSIRT case file.

Unmaintained components and replacement

Where a component has no maintainer, Art 13(6) imposes no upstream duty, but the product duty remains. Document the finding, the risk, the mitigation (isolation, feature removal, own patch) and a dated replacement plan. Add a review trigger to the risk

assessment; the guidance encourages informing the community through public vulnerability records even without a maintainer.

When the product itself is open source

A monetised open-source product makes its publisher a manufacturer with the full CRA. An unmonetised one from a legal person makes the publisher a steward with Art 24 duties only; non-monetising natural persons have no obligations. The tests are in Open-source software; two engineering consequences follow.

First, Art 32(5): a FOSS product in an Annex III category may use any conformity route, including Module A. The condition is that the Annex VII technical documentation is made public when the product is placed on the market. Publishing the technical file means publishing the risk assessment, the SBOM, the test reports and the vulnerability-handling description.

Decide what the risk assessment can say in public before relying on this route. Redact nothing that the file needs to be complete.

Second, the open-core split. The paid edition is placed on the market and the free community edition is not, even on a near-identical codebase (guidance paras 52-53).

The company is manufacturer for the paid edition and steward for the community edition, per project. Keep one codebase but two sets of records.

The paid edition needs a full Annex VII file and declaration. The community edition needs an Art 24(1) cybersecurity policy.

The project's SECURITY.md and policy

For the community edition, the steward's Art 24(1) policy must be documented "in a verifiable manner". It covers secure development, vulnerability documentation and remediation, voluntary reporting under Art 15 and information sharing within the community. For the paid edition, the same file doubles as the Part II point 5 CVD policy.

The ORC WG steward white paper V1.0 (January 2026, marked "not legal guidance") recommends keeping the evidence in version-controlled files.

- [ ] Reporting channel, PGP key and expected response times (section 8 targets)
- [ ] Supported versions and the fix policy per branch, with end-of-support dates
- [ ] Disclosure timeline, embargo rules and the accelerated path for actively exploited vulnerabilities
- [ ] Where advisories are published (GitHub Security Advisories, CSAF endpoint) and how CVE and EUVD IDs are obtained

- [ ] Secure-development practices: review requirements, signed releases, SBOM per release, dependency policy
- [ ] How the project shares information with downstream manufacturers and upstream dependencies
- [ ] For the steward: the legal entity acting as steward, the type of support it provides and the Art 24(3) reporting consequence
- [ ] Review date and owner

Stewards cannot CE-mark, need no SBOM or technical file, and are exempt from fines. Art 24 applies only from 11 Dec 2027, and a steward that starts monetising becomes a manufacturer from that date (guidance para 84).

References and open points

Use the ORC WG deliverables with care. The steward white paper is shipped, the due-diligence white paper D3.2 is work in progress, and the D4.x specifications are not shipped. OpenSSF resources are the Stewards Playbook, the OSPS Baseline and the manufacturer checklist linked from its 11 Sep 2026 guide.

OpenSSF itself puts the Baseline's coverage of manufacturer duties at about 35% (Tech Talk recap).

Two monetisation patterns are unresolved in the guidance: dual licensing and paid hosting of an otherwise free project. The nearest analogues are the open-core treatment and the rule that monetising services around the software can place it on the market (para 54). Record a FOSS determination memo per project, note the reliance on Commission interpretation, and take legal advice before relying on either pattern.

The due-diligence records and FOSS determination memo serve checklists 3, 4 and 9 in the Requirement checklists tab.

10. Product-level reporting runbook

The product team's job in an Art 14 case is to supply the facts fast enough for a filing within 24 hours. The clocks, the Single Reporting Platform, the registration steps and the fallbacks are in Reporting obligations (Article 14). This section lists what the product team contributes, in the form the ENISA SRP glossary fields need.

Art 14 has applied since 11 Sep 2026 to every in-scope product, including products no longer sold or past support (Art 69(3); para 210). The reportable inventory therefore includes every version in the field.

Awareness decision inputs

Awareness arrives when, after an immediate initial assessment, the manufacturer has "a reasonable degree of certainty" of exploitation or a severe incident. The source is guidance C(2026) 5252 para 213. The product team owns most of the inputs to that assessment and must deliver them within hours.

Input	Product-team source	What to hand over
Product telemetry	Crash reports, authentication-failure spikes, anomalous update or command traffic, integrity-event logs (Annex I items 2(d), 2(f), 2(l))	Timeline of anomalous events in UTC; affected versions; whether evidence shows exploitation or only vulnerability
Honeypots and canaries	Exposed decoy units or endpoints for the product class	Capture of exploitation attempts; indicators; whether the attack path works against shipped versions
Customer and partner reports	Support tickets, integrator escalations, PSIRT intake (section 8)	Reproduction status; affected configurations; exploitation evidence quality
Third-party intelligence	CSIRT or ENISA notices, researcher contact, vendor advisories, KEV additions for a component, media reporting	Reachability analysis for component findings; whether the exploited path exists in the product
Internal findings	Test results, scanner hits, bug-bounty submissions	Marked "no exploitation evidence" unless telemetry says otherwise; these are not actively exploited vulnerabilities on their own (Commission FAQ v1.4 section 5)

The PSIRT case file (section 8) records each input with its UTC time. The incident commander declares awareness; monitoring these channels is good practice, not itself mandated.

Product data every notification needs

Keep a current product data pack per product family so the notification owner never has to ask engineering for basics under the clock.

Field (glossary name where applicable)	Content	Owner
Product name and version	Commercial name, model, firmware and app versions affected; version-support status	Release engineering
Product type, class and category	From the product definition record (section 2); "default" if no Annex III or IV match	Compliance lead
Affected configurations	Hardware revisions, feature flags, deployment modes, RDPS dependencies affected	Product security
Component name	Upstream component and version where the vulnerability sits; VEX status	SBOM owner
Member States where available	Current distribution map per product, maintained from sales and app-store data; drives dissemination under Art 16(2)	Product management
End-of-support indicator	Whether any affected version is past its declared end date	Product management
Mitigating measure expected shortly; user action able to reduce impact	Yes or no, and the interim guidance text	Remediation lead
CVE ID and EUVD ID	Only once assigned; a CVE record is not a notification	PSIRT
Date and time became aware	UTC, from the case file; estimates labelled	Incident commander
Attack vector	Network, adjacent, local, physical, with the reachability note	Product security

A stale distribution map is the most common blocker to a 24-hour filing. The "Member States where product available" field is required at early warning.

Content by stage

Stage	Product team supplies	Glossary fields served
Early warning (24 h)	Title and summary; product name and version; Member States; awareness time in UTC; for incidents, whether malicious or unlawful acts are suspected	Type, Title, Summary, Product name and version, Member States, Date/time became aware, Incident suspected of unlawful or malicious acts
72-hour notification	General information on the vulnerability and exploit, or the incident and initial assessment; corrective or mitigating measures taken; measures users can take; sensitivity view; attack vector; whether to request limited dissemination	General information, Initial assessment, Corrective or mitigating measures taken, Corrective or mitigating measures users can take, Considered sensitivity, Attack vector, PEC indicator
Final report (14 days after a fix for vulnerabilities; 1 month after the 72-hour report for incidents)	Severity rating, classification and rationale; impact description; malicious actor if known, else "unknown"; details of the security update; date the measure became available; root cause for incidents	Description of severity and impact, Malicious actor, Details of the security update, Date corrective measure became available, Type of threat or root cause, Applied and ongoing mitigation

No severity scale is prescribed; supply the CVSS vector and a plain-language rationale. Track the date a fix became available internally, because the vulnerability final report has no platform counter.

User notification (Art 14(8))

After awareness the manufacturer informs impacted users and, where appropriate, all users without undue delay, including mitigating measures, "where appropriate" in a machine-readable format. Guidance paras 219-221 make this proportionate: affected customers may receive detail before a fix exists and the wider public once mitigated. The product team prepares both forms.

- Human-readable: in-product notice, app notification or email with the interim action, the fix version and the advisory link. The same text travels with the update as its advisory message (section 7).

- Machine-readable: a CSAF advisory, with a VEX "under_investigation" or "known_affected" status until the fix, then the final advisory with fixed versions (section 8). CSAF is the obvious candidate and appears in no primary source as a required format.
- Channel list per product: which users can be reached directly, which only through distributors or integrators, and which only through the public page. A CSIRT may inform users if the manufacturer is not timely.

Link to the PSIRT case

One identifier binds the case file, the VEX and CSAF documents, the SRP notification reference, the user notices and the fixing release. Record the SRP notification ID in the case once filed. The platform stores drafts only in the individual filer's account, so the case file is the authoritative record.

After the final report, file the post-incident review against the case and update the risk assessment rows affected (section 3).

Timeline from first signal to final report

Step	Owner	Target	Output
1 First signal logged	PSIRT on-call	Within 1 hour of receipt	Case opened; UTC first-signal time
2 Initial assessment	Product security analyst with incident commander	Immediately; hours, not days	Reachability, exploitation evidence, severity; awareness declared or not, with UTC time
3 Product data pack checked	Release engineering and product management	Within 4 hours of awareness	Versions, configurations, Member States, support status confirmed
4 Early warning drafted and filed	Notification owner (24 h) with incident commander	Within 24 hours of awareness	SRP notification ID recorded in the case
5 User interim notice	Remediation lead with communications	Without undue delay; affected customers first	Interim guidance, human-readable and CSAF

Step	Owner	Target	Output
6 72-hour notification	Notification owner (72 h) with legal review	Within 72 hours of awareness	General information, measures, sensitivity view
7 Fix built, tested and released	Remediation lead; release engineering	Per severity SLA; security-only release	Signed update; gate record; CSAF final advisory
8 Final report	Notification owner (final)	14 days after the fix is available (vulnerability); 1 month after step 6 (incident)	Severity, impact, actor, update details
9 Post-incident review	PSIRT lead; product security	Within 2 weeks of the final report	Case closed; risk assessment and test plan updated; drill lessons

Treat the 24-hour and 72-hour deadlines as both running from awareness, not consecutively; remediation never pauses the clock. Two paper exercises a year, one vulnerability and one incident, keep the data pack and the roles honest. Never submit synthetic reports to the live platform.

The product data pack and case-file links are the product team's contribution to checklist 5, reporting, in the Requirement checklists tab.

11. The documentation set per product

Three documents leave the engineering process for every product version: the Annex VII file, the Annex II user information and the declaration of conformity. Their legal contents are in Conformity assessment and documentation and Annex I Part II: vulnerability handling and lifecycle duties. This section gives the file structure, the publication mechanics and the versioning rules.

The Annex VII file structure

No authority publishes an Annex VII template. BSI TR-03183-1 v1.0.0 section 4.8 lists the minimum content of an assessment report, which "can therefore form part of the technical documentation". The outline below uses it as the skeleton and maps each part to the Annex VII point it satisfies.

1. **Cover and control.** Product name, model and variants; file version; date; author and approver; retention date (Art 13(13)). Language note: any language internally, translatable for an authority on reasoned request (Art 13(22)).
2. **Product identification.** Intended purpose and foreseeable use from the product definition record (section 2); hardware and software versions affecting compliance. For hardware, photographs or illustrations of external features, markings and internal layout. The remote-function map and the family variant list. Annex VII point 1(a)-(c).
3. **Risk context.** Operational environment, user profile, assets in the three classes, attacker profile, expected time in use. Feeds Annex VII point 3.
4. **Risk assessment.** Threat model and data-flow diagrams; evaluated risks; accepted risks with treatment. The Annex I Part I applicability matrix with justifications, and the Part I point (1) and Part II application statements (section 3). Annex VII point 3.
5. **Design documentation.** Architecture including network and physical interfaces and how software components build on each other. Selected controls with the risk each mitigates and the Annex I item each serves. Non-applicable items with justification; implementation description; verification approach. Annex VII point 2(a).
6. **Vulnerability handling.** The SBOM reference and hash per version; CVD policy; evidence of the reporting contact (security.txt and Annex II point 2). The update design note (section 7), the PSIRT process description (section 8) and upstream reporting records. Annex VII point 2(b).
7. **Production and monitoring.** Build and release process, signing, gate records, series-production conformity measures (Art 13(14)). Annex VII point 2(c).
8. **Support period.** Declared period per variant and version with the information used to determine it under Art 13(8); the version-support matrix; end-of-support communication plan. Annex VII point 4.
9. **Standards and specifications.** Harmonised standards, common specifications or certification schemes applied in full or in part. Where none applies, the solutions adopted and the specifications used, labelled draft where they are drafts. Annex VII point 5.
10. **Test reports.** Product tests against Part I and process tests against Part II, indexed by requirement (section 12 evidence index). Annex VII point 6.
11. **User documentation.** The Annex II document and its published URL. Annex VII point 1(d).
12. **Declaration.** Copy of the EU declaration of conformity. Annex VII point 7.
13. **SBOM annex.** The SBOM itself, held for supply on a market surveillance authority's reasoned request. Annex VII point 8.

Products designed before 11 Dec 2027 may state where historical design evidence is replaced by the risk assessment (guidance paras 37-39). Say so in part 5.

The Annex II user-information document

Annex II lists what must accompany the product "at minimum", in paper or electronic form (Art 13(18)). It stays available for 10 years or the support period and is kept online where provided online. The point-by-point checklist is in Annex I Part II: vulnerability handling and lifecycle duties; write it as one versioned document per product or family.

- Publish at a stable URL of the form `/security/<product>/<version>/` with a `latest` alias, and never delete a version page while its retention runs.
- Point 2 carries the same contact and policy URL as security.txt; point 6 carries the exact declaration URL.
- Point 7 carries the end month and year per version.
- Point 8(e) explains the opt-out from automatic security updates; point 9 appears only if you choose to give users the SBOM.
- Point 5 is where residual-risk treatment by user information lands (section 3); write it as concrete conditions and compensating measures, not a disclaimer.
- Point 8(f) applies to components intended for integration. It must give integrators what they need for their own Annex I and Annex VII work (section 4 integrator pattern).
- Language: easily understood by users and by market surveillance authorities in the Member States of sale.

The same page can host the CE marking for software, the declaration, the advisory index and the archive warnings. That satisfies Art 30(1), Annex VI, Annex II and the public-page expectations of BSI TR-03183-3 in one place.

The EU declaration of conformity

Draw up one declaration per product following the Annex V structure, with the eight elements listed in Conformity assessment and documentation. Keep it "updated as appropriate" and in the languages required by the Member States of sale (Art 28). Element 6 cites standards used, which today means none cited and possibly drafts named as specifications.

Element 7 names the notified body, procedure and certificate where Module B+C or H applies.

Signing: the person signing acts for the manufacturer and assumes responsibility for compliance (Art 28(4)). Name the function, place and date, and keep the signing authority with the executive sponsor or a written delegate. Where several Union acts apply, one declaration or a dossier of declarations covers all of them (Art 28(3)).

The simplified Annex VI form reads "Hereby, [manufacturer] declares that the product with digital elements type [...]" complies with Regulation (EU) 2024/2847. It then gives "the exact internet address" of the full declaration (Art 13(20)). Use it in packaging and in-

app screens; the full declaration lives at that address and a copy sits in the technical file.

A product family may share one declaration that "clearly identifies the product variants" (guidance paras 174-177).

CE marking placement

Hardware carries the CE marking visibly, legibly and indelibly on the product, else on the packaging and the declaration. It may be under 5 mm where the product's nature warrants it (Art 30(1)-(2)). Software carries it on the declaration or on the accompanying website, in a section consumers can reach directly (Art 30(1)).

For app-store software no authority has said how the store listing should present it. Put it on the declaration and the security page.

Affix it before placing on the market and only after a positive conformity assessment (Commission FAQ v1.4 section 6.7). The notified body's identification number follows the CE marking only under Module H (Art 30(4)).

Support-period declaration and end-of-support notice

Declare the support period per variant and, for software, per substantially modified version. Show the end month and year at the time of purchase on the product, packaging or digitally (Art 13(19)). Five years is a floor, not a default (guidance paras 125-128).

Design an in-product or in-app end-of-support notification where technically feasible. Plan the notice content now: date reached, risk of continued use, upgrade path, archive warning text under Art 13(11).

Keep a version-support register: version, placing date, declared end date, what was shown at purchase, update channel, migration path, legacy-version owner. It feeds Annex VII part 8, Annex II point 7 and the Art 13(10) decision.

Versioning and retention tied to each placing

Every placing on the market freezes a document set. For hardware that is each unit shipment against the file version current at the time.

For software it is the first offering of each version (guidance paras 11-16). Record the mapping from product version to file, Annex II and declaration versions in the release gate record (section 5).

Retention runs 10 years from placing or the support period, whichever is longer. It covers the file and declaration (Art 13(13)) and the Annex II information (Art 13(18)).

A substantial modification produces a new placing, a new declaration and a new file version while the earlier versions stay retained. Store the set under version control with signed tags, mirrored to immutable storage independent of any repository provider.

Product-family variant list

One file, one assessment and one declaration may cover a family that shares architecture, security-relevant design, intended purpose and risks (guidance paras 174-177). Maintain a variant list inside the file and the declaration.

Variant	Model and SKU	Differences from the reference variant	Interfaces, stack, update path or connectivity differences	Affected matrix rows	Separate evidence	Declared end of support
Reference		None	None	None	Full set	
Variant A		For example, no cellular modem	Interface removed; emitter inventory differs	2(i), 2(j)	Port scan for variant A	
Variant B		For example, retail firmware with cloud onboarding	Additional RDPS function	2(d), 2(e), 2(h) boundary rows	Boundary tests for variant B	

A difference in the update mechanism or remote connectivity usually means a new family rather than a variant; when in doubt, split.

The three documents close checklists 6, Annex II, and 7, documentation and declaration, in the Requirement checklists tab.

12. Preparing for conformity assessment

Prepare the same evidence whichever route the product takes, because a notified body asks for exactly what Module A asks you to hold yourself. The routes by class, the Annex VIII modules and the notified-body landscape are in Conformity assessment and documentation. This section is the preparation procedure.

As of 30 Oct 2026 no harmonised standard is cited and no CRA notified body is designated. Class I products cannot yet use Module A and no body can yet be engaged.

What a Module A record contains

Module A (Annex VIII Part I) has no external party, so the record is the proof that the manufacturer did the work. It holds the Annex VII technical documentation (section 11) and the measures ensuring that design, development, production and vulnerability

handling conform (points 2 and 3).

It also holds the declaration drawn up on the manufacturer's sole responsibility (point 4.2) and the CE marking decision (point 4.1).

Make it a signed internal-control report: scope and product version; the evidence index with every requirement closed; the applicability matrix sign-off. Add the gate record of the release declared, the release-approval minute and the declaration. The person who signs the declaration signs the record, with authority held by the executive sponsor or a written delegate (section 11).

Retain it with the file for 10 years or the support period.

Default-class products use Module A today. A FOSS product in Annex III may use it if the technical file is public (Art 32(5)). Everyone else keeps the same record complete as the fallback and as the body's input.

What a notified body asks for under Module B

Module B (EU-type examination) examines the technical design and the vulnerability-handling processes and attests both. The application goes to a single body (Annex VIII Module B point 3).

It contains the manufacturer's name and address and a declaration that no other body holds it. It also contains the technical documentation, including "an adequate risk analysis" and the Annex VII elements, plus supporting evidence with test results where needed.

The body examines the documentation, verifies that specimens match it, tests the application of any standards chosen and tests non-standard solutions (point 4).

Prepare a pack with these parts.

- The Annex VII file and the risk assessment with the applicability matrix and the decision trail (section 3)
- Specimens of the product and of each critical part, built from the release under assessment, with an inventory of serials, image hashes and configuration
- Vulnerability-handling process evidence: the CVD policy, the live security.txt, the PSIRT procedure, case files and advisories (section 8)
- The update design note and tests (section 7); the SBOM and VEX per release (section 6)
- Test reports indexed by requirement

The body audits vulnerability handling periodically after certification (point 8), so the PSIRT records must keep accumulating.

What a notified body asks for under Module H

Module H (full quality assurance) approves a quality system covering design, development, final inspection and testing, and vulnerability handling, maintained through the support period. The application (point 3.1) contains the manufacturer's details, technical documentation for one model per product category, the quality-system documentation and the no-other-body declaration. The audit team includes a product-experienced assessor and the audit includes a site visit where premises exist (point 3.3).

Surveillance means periodic audits plus site access (point 4).

Define the quality-system scope to include firmware, build pipelines, signing infrastructure and the update service; scopes that exclude them are a reported failure pattern. Pick one representative technical file per product category and bring it to the standard of section 11.

BSI TR-03183-H v1.1.0 (non-binding) shows how an extended ISO/IEC 27001 ISMS carries Module H. It refines clauses 4.2 to 8.1 and controls 5.7, 5.8, 8.8, 8.25, 8.29 and 8.32. ISO 9000 certification alone does not satisfy the module.

The evidence index

Build one index per product or family and keep it current from the release gate. It is the first page a body or an authority reads, and it is the Module A record's spine.

Requirement	Evidence	Location	Owner	Date
Annex I Part I 2(a)	Gate record G-2026.11 with KEV check; VEX V-031; scan reports	repo/evidence/releases/2.4.1/	Product security	2026-11-05
Annex I Part I 2(b)	Default-config baseline FC-09; reset test RT-02; provisioning record P-02	repo/evidence/controls/2b/	Firmware lead	2026-10-20
Annex I Part I 2(c)	Update design note UDN-3; tests UT-01 to UT-12	repo/evidence/update/	Platform lead	2026-10-22

Requirement	Evidence	Location	Owner	Date
Annex I Part II(1)	Signed SBOM S-2026.10, sbomqs score, attestation	artefact store, release 2.4.1	SBOM owner	2026-11-05
Annex I Part II(5), (6)	CVD policy v3; security.txt capture; intake monitoring log	security site; repo/evidence/psirt/	PSIRT lead	2026-10-01
Art 13(3)-(4)	Risk assessment RA-7 with applicability matrix and change log	repo/evidence/risk/	Product security	2026-10-28
Art 13(8)	Support-period determination SP-2; version-support register	repo/evidence/support/	Product management	2026-10-15
Annex II	User information v2.4 at the versioned URL	security site	Technical writing	2026-11-05
Annex V	Declaration D-2026-02 signed	repo/evidence/doc/	Compliance lead	2026-11-06

Add one row per Annex I item, per Part II point, per Art 13 paragraph that needs evidence, and per Annex VII point. Every evidence identifier resolves to a file under version control or in the artefact store; nothing resolves to a mailbox.

Pre-assessment and gap review

Run a gap review on one representative product before engaging anyone, using the evidence index and the Requirement checklists tab. Score each row as present, partial or missing with the owner and the fix date. Record the review itself as evidence of the Module A point 3 measures.

Labs sell readiness assessments and "Module B+C simulations" (TÜViT, DEKRA, Brightsight, Applus+, UL; vendor offers). They give an outside reading of the file but confer no conformity status.

Have someone outside engineering read the file for completeness and traceability. The failure mode early adopters report is not weak security but security that "could not show the decision trail".

Substantial modifications with the body

Under Module B the manufacturer must inform the body of any modification that may affect conformity or certificate validity. Such modifications need approval as an addition to the certificate (Module B point 7).

Report every positive security-delta decision from the release gate (section 5). Report borderline negative decisions with the reasoning too, since the information duty is wider than the test.

Under Module H, intended changes to the quality system go to the body (point 3.5). New or substantially modified products extend the approved system through the same body in a streamlined process (Commission FAQ v1.4 section 6.3).

A substantial modification is a new placing on the market. The re-assessment focuses on the modified parts and reuses unaffected documentation (guidance C(2026) 5252 paras 116, 122-123). Keep the delta assessment and the body's response together in the file.

While no body is designated

Keep the Module A paperwork complete for every product, including Class I, Class II and critical products that will need a body. The record, the evidence index and the file are the application pack once a body exists. They are also what a market surveillance authority can request from 11 Dec 2027 regardless of route.

Pre-contract two or three candidates now. Brightsight holds RvA accreditation pending Dutch notification and Applus+ is in the accreditation process (both vendor statements); others state they will apply. Ask each for its intended modules, accreditation status, expected designation date and a conditional engagement letter, and check NANDO before signing anything.

Track the OJ for harmonised-standard citations. A citation of a vertical standard covering the product's core functionality reopens Module A for Class I products if applied in full. Aligning the file to the draft's clause structure now reduces re-work.

Timelines

All figures are vendor or commentator estimates and none comes from an authority or a designated body.

Item	Estimate	Source
Accreditation plus notification per body	12 to 18 months	CRA Decoded, commentary
Finding and contracting a body	2 to 4 months	CRA Decoded, commentary
Module B+C engagement once engaged	3 to 6 months; 3 to 12 months for complex products	CRA Decoded; sota.io, vendor, unsourced
Module H surveillance	Every 1 to 2 years	CRA Decoded, commentary
Module B examination fee	EUR 20,000 to 60,000; EUR 15,000 to 80,000	CRA Decoded; sota.io, vendor, unsourced
First Module H engagement	EUR 80,000 to 150,000	CRA Decoded, commentary

Working back from 11 Dec 2027 on those estimates means contracting by the first quarter of 2027. Plan on that basis and label it as an estimate in the programme plan. Keep the Module A record complete as the only part of the timeline you control.

13. Worked example: a connected device with a mobile app and a vendor backend

A fictional smart thermostat, the Thermostat T200, shows the guide applied end to end. The product comprises device firmware, iOS and Android apps, and a vendor cloud for remote control and updates hosted on third-party IaaS. A third-party weather API feeds scheduling; the manufacturer, Example GmbH, is established in Germany and sells across the EU through retail and installers.

Section 2: boundary, class and route

The product is the device, the two apps, and two cloud modules: the remote-control service and the update service. Both cloud modules pass the three-element test.

They process at a distance and a product function fails without them. Example GmbH built them to its own design on IaaS (guidance paras 184-196; thermostat example in section 8.3).

The IaaS hypervisor and the account database the app never talks to are outside the product and are recorded as dependencies (para 205).

The weather API is a licensed third-party service, so it fails element (iii). It is a component under Art 13(5), not RDPS, and the remote-function map records "weather API: scheduling input, provider X, fallback to last-known forecast". Telemetry sent for product analytics is not RDPS (para 192) and is off by default under item 2(g).

Intended purpose: residential heating control by consumers, with optional installer configuration, expected in use for 10 years. Core functionality is heating control. Nothing in Implementing Regulation (EU) 2025/2392 matches.

The Class I smart-home categories cover general-purpose virtual assistants and products with security functionalities such as locks, cameras and alarms (see Product classification). The T200 has a presence sensor for scheduling but no security function, so it is default class and the route is Module A. The record notes the review trigger: adding a door-sensor integration or a camera would re-run the test.

Variants: T200 with cellular backup and T200 Wi-Fi only share architecture and security design, so one family. The emitter inventory and the 2(i) and 2(j) rows differ.

The support period is 10 years to match expected use, declared per variant. Firmware releases are per-version placings and app releases follow the hardware units.

Section 3: risk assessment highlights

Method: BSI TR-03183-1 structure with STRIDE on the data-flow diagram covering device, apps, remote-control service, update service, weather API and installer laptop. Assets: boiler-control function and setpoints (functional); account credentials, device keys, occupancy data (data); root of trust, update signing keys, audit log (security). Attacker profile: opportunistic remote attackers and a local attacker on the home network; no capable-adversary assumption, recorded with reasoning.

Threat and asset	Item and control	Residual risk and treatment
Replayed or forged remote command turns heating off in winter (boiler-control function)	2(f) and 2(d): device-bound signed commands with nonce; mutual TLS to the control service; local override always available	Low; residual on clock drift covered by signed time; Annex II point 5 states the local override
Occupancy data exposes when the home is empty (occupancy data)	2(g) and 2(e): presence used only on-device for scheduling; cloud receives setpoints only; TLS 1.3; encrypted at rest with device-wrapped key	Low; justification for 2(g) applicability recorded with the data inventory

Threat and asset	Item and control	Residual risk and treatment
Compromised update signing key pushes malicious firmware (signing keys)	2(f) and 2(c): offline root in HSM, online targets key in KMS, two-person release approval, anti-rollback counter	Low; key-rotation test UT-09; recovery image; residual accepted with monitoring of signing events

All thirteen items apply except 2(m) transfer. It is marked not applicable because no exportable data exists beyond schedules, which the app can re-create. Annex II point 8(d) carries the erase procedure.

Section 4: the items that bite hardest

Item 2(b): per-unit pairing codes printed under the faceplate, no default account, debug UART locked by fuse in production, Bluetooth pairing limited to onboarding. Item 2(c): automatic security updates on by default, in-app postpone of up to 7 days, a labelled opt-out; installers set maintenance windows.

Item 2(h): heating control continues on the local schedule when the cloud is unreachable, tested with a 72-hour outage.

Item 2(i): the device's only emitters are the control-service connection, the update check and NTP; retry back-off is tested. Item 2(l): authentication, pairing, update and integrity events are logged and exportable from the app, with an opt-out that keeps update and integrity events. The RDPS boundary rows follow draft EN 304 621 Annex R (draft): both ends authenticate, check integrity and freshness, and define behaviour on loss.

Section 5: lifecycle

Design review on every firmware or service change; component intake for every dependency. SAST runs on every candidate, fuzzing covers the command parser and the weather-API response parser, and DAST covers the control-service API. The release gate records the SBOM hash, the KEV check, the secure-default export, the security-delta answers and the declaration decision.

Firmware 2.4.1, a security-only release fixing the command-replay flaw, answered all four guidance questions negatively and shipped under the existing declaration.

Sections 6 and 7: SBOM and update design

SBOMs: Yocto-generated CycloneDX 1.6 for the firmware image, cdxgen for each app bundle, Syft on each service container. Each is enriched to the TR-03183-2 fields, scored with sbomqs, attested with cosign and uploaded to Dependency-Track with an EUVD

watch. Depth recurses to the first component outside the delivery scope; the weather API appears in the remote-function map, not the SBOM.

VEX is produced per release; no vulnerability data enters the SBOM.

Updates: TUF-style metadata with root, targets, snapshot and timestamp roles; A/B firmware slots with power-fail recovery; a monotonic version counter. First-boot update runs before onboarding completes, security and feature trains are separated by maintenance branches, and the advisory text travels with each update. The update repository is immutable storage budgeted for 10 years after the last release, with archive pages carrying the Art 13(11) warning.

Sections 8 and 10: CVD and reporting data

security.txt sits at the example.com well-known path with psirt@example.com, the anonymous form, the PGP key, the CVD policy URL and the CSAF provider metadata. A monitored phone line satisfies Art 13(17). Targets: acknowledgement in 5 working days, detailed response in 10, disclosure default 90 days.

Example GmbH's coordinating CSIRT is Germany's; two Assigned Representatives are registered on the SRP (see Reporting obligations (Article 14)).

The product data pack holds firmware and app versions, hardware revisions, configuration flags and the distribution map (14 Member States). It also holds end-of-support dates and the component list with VEX status.

For the replay flaw, telemetry showed probing but no successful exploitation. The incident commander recorded "no awareness of active exploitation" with reasoning and no Art 14 report was filed.

The fix shipped with a CSAF advisory carrying the CVE and EUVD IDs within the 90-day window.

Sections 11 and 12: documentation and declaration

The Annex VII file follows the thirteen-part outline, one file for the family with a variant list. The Annex II document sits at a versioned URL with the CE marking for the apps, the Annex VI text and the full declaration. The same page holds the support-period table (end of support November 2036 for first-batch units), the advisory index and the archive warnings.

The device carries the CE marking on the back plate and the end month and year on the packaging. The app shows the end-of-support notice when reached.

The Module A record is a signed internal-control report. It holds the evidence index, the gate record for firmware 2.4.0 and apps 3.1, and the applicability matrix sign-off.

The managing director signs the declaration. The record is retained with the file for 10 years after the last unit is placed or the support period, whichever is longer.

Artefacts produced

- Product definition record with remote-function map and variant list
- Art 13 risk assessment RA-7 with data-flow diagram, threat list, applicability matrix and change log
- Control implementation notes and acceptance test records per Annex I item, including RDPS boundary tests
- Release gate records per firmware, app and service release with security-delta decisions
- Signed SBOMs, sbomqs scores, attestations and VEX documents per release
- Update design note with key hierarchy, metadata, recovery and the twelve acceptance tests
- CVD policy, security.txt, PSIRT procedure, case files and CSAF advisories
- Component due-diligence records, including the weather API and the TLS library
- Reporting data pack and distribution map; awareness decision records
- Annex VII technical file for the family; Annex II document at a versioned URL
- EU declaration of conformity and the Annex VI simplified text; CE marking placement record
- Module A internal-control record with the evidence index

Each artefact above maps to a line in the Requirement checklists tab, from checklist 1 scope gate to checklist 8 modules.

14. Application-level pitfalls

These are the product-level mistakes that recur in early-adopter reports and vendor teardowns, each with the countermeasure this guide prescribes. The programme-level pitfalls are in Engineering compliance programme. Sources are the Commission FAQ v1.4, guidance C(2026) 5252, BSI TR-03183-2 and vendor material from Finite State and OmniTrust.

- SBOM generated from the manifest misses vendored and statically linked code. Generate from the shipped artefact at build and add binary scanning (section 6).
- Vulnerability data embedded in the SBOM goes stale and breaks the BSI profile. Keep status in VEX and CSAF beside a static SBOM (sections 6 and 8).

- CVE counts or scanner hits treated as risk or as active exploitation. Apply reachability, record VEX justifications and reserve Art 14 for reliable exploitation evidence (sections 3, 8, 10).
- Default credentials or shared secrets shipped for convenience. Provision per-unit secrets, force credential set-up at first use and test the fresh-install export (section 4, item 2(b)).
- Debug ports left enabled in production units. Lock JTAG, SWD and UART by fuse or configuration and verify by attempting a debugger attach (section 4, item 2(j)).
- Telemetry on by default and justified as product improvement. Inventory every data item, default telemetry off with opt-in and record the 2(g) justification (section 4).
- Logging without a user opt-out, or an opt-out that silently disables security events. Provide the control, document which events persist and why, and say so in Annex II (section 4, item 2(l)).
- Updates verified by signature but without anti-rollback, so an attacker reinstalls a vulnerable version. Add a monotonic counter and an audited downgrade path (section 7).
- Security fixes bundled into feature releases because one train is easier. Run maintenance branches with a security-only channel and record any exception per FAQ section 4.3 (sections 5, 7).
- No per-version support declaration for software, so nobody knows which versions receive fixes. Keep a version-support register with end month and year and the Art 13(10) upgrade path (sections 7, 11).
- Evidence not linked to releases and assembled by hand when asked. Emit gate records, SBOM hashes, test results and attestations in CI and index them per requirement (sections 5, 12).
- The manufacturer-built backend left out of the risk assessment because "it is cloud". Apply the three-element test, map every remote function and assess both ends of each RDPS boundary (sections 2, 4).
- A weather-API-style third-party service treated as RDPS and assessed as the manufacturer's own. It fails element (iii) and belongs under Art 13(5) due diligence with product-level mitigations (sections 2, 9).